

三端架构 ONE PRODUCT · THREE REPOS

- **koi-recall-web** · C 端消费者站 www.koiimprtinc.com
召回查询 / 产品校验 / 索赔提交 / 进度跟踪
- **koi-recall-admin** · B 端运营后台 admin.koiimprtinc.com
案件审核 / 处置管理 / 退款 / 合规审计
- **koi-recall-backend** · API 服务 koi-recall-backend.vercel.app
Hono + Drizzle · OpenAPI 3.1 契约单一事实源

所用技术 TECH STACK

- **前端**:Next.js 16 · React 19 · TypeScript · Tailwind v4 · Ant Design 6(Admin)
- **后端**:Hono 4 · Drizzle ORM · PostgreSQL(Neon)· Node.js 24
- **能力**:Vercel Blob · Resend + Svix · Upstash 限流 · Vercel Cron
- **质量**:Vitest 三层测试 · ESLint + Prettier · openapi:check 门禁

核心业务流程 CORE PIPELINE · 9 STEPS

- ① **浏览召回** → ② 产品预筛 → ③ 索赔草稿 + 证据直传 → ④ 提交建案(加密 · 幂等 · 单事务)
- ⑤ **后台审核**(10 态状态机)→ ⑥ 补偿 Resolution → ⑦ 消费者处置 Disposal
- ⑧ **邮件通知**(Outbox → Resend → Svix 回执)⑨ 事故 · CPSC 可报告性闭环

功能需求 FUNCTIONAL SCOPE

- **C 端 6+ 页面**:召回详情"三刀流" · 免注册查询 · 用户中心 · 处置任务页
- **B 端 10 模块**:案件审核全流程 · 6 运营队列 · 退款导出 · 处置内容库
- **API 4 组端点**:/v1 消费者 · /admin 管理 · /webhooks · /internal
- **数据模型**:10 个 schema 文件 · 46 张表 · 24 个迁移

实施阶段 DELIVERY ROADMAP

- **Phase 1 · 后端先行**:契约骨架 → 46 表建模 → ToC API → 前端接入
- **Phase 2 · Admin 全量接 API**:Resolution / Workflow / Refund 四大工作流
- **能力增强**:邮件全链路 · 缓存标签按需失效 · 发布接口 · 跨实例限流
- **事故整改**:处置一致性 P0-A → escalated P0-B → P1(A01-A35)

安全与合规 SECURITY & COMPLIANCE

- **数据**:AES-256-GCM 字段加密 · HMAC 查询哈希 · 两级 PII 脱敏
- **权限**:RBAC 双角色(ADMIN / MANAGER)· 审计事件全留痕
- **防护**:Upstash 限流 · Idempotency-Key 幂等 · Svix 验签
- **合规**:CPSC 可报告性闭环 · closure_review 双门问 · escalated 强制升级

KOI RECALL PLATFORM

KOI Recall 召回平台

koiimprtinc.com · CPSC 消费品召回
查询 — 索赔 — 审核 — 补偿 — 处置 全流程

TECHNOLOGY STACK

所用技术导图 三端技术栈 · 基础设施 · 工程化

前后端均为 TypeScript 全栈,OpenAPI 契约贯穿三端,CI 门禁保障契约与数据库结构不漂移。

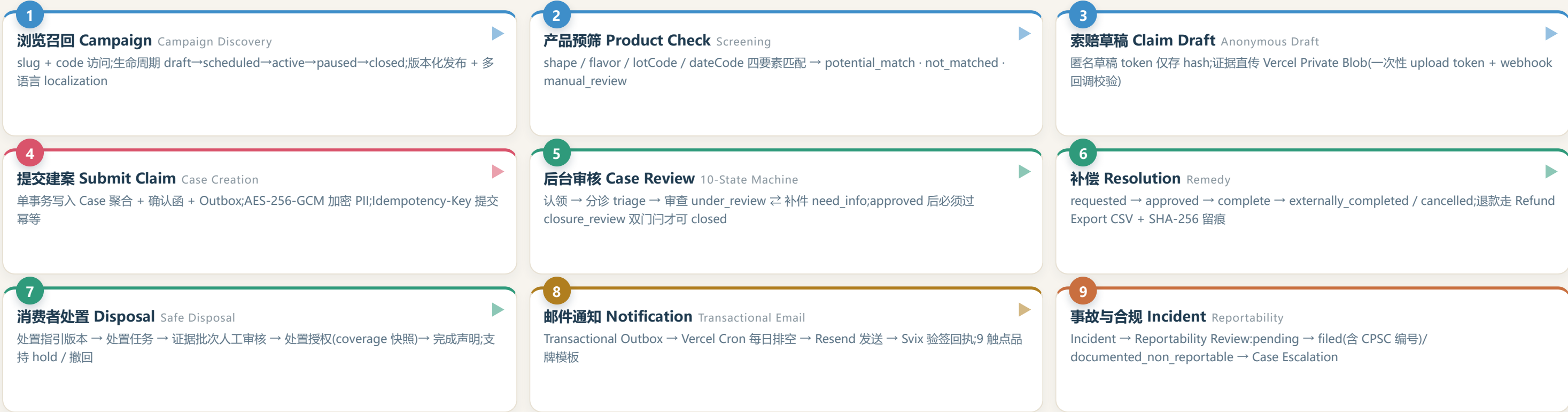


IMPLEMENTATION PIPELINE

实现步骤导图 业务主线 · 状态机 · 研发路线

完整链路:Claim Draft → 提交建案 KOI-XXXX-XXXXXXXX → Admin 处理同一 Case;前后端流转规则由 CaseWorkflowPolicy 单一函数保证不漂移。

A 核心业务主线 END-TO-END · 9 STEPS



B 案件状态机 10 STATES · 4 TERMINAL



双门门关闭:approved → closed 已移除,必须同时满足 ① Resolution externally_completed ② Reportability 已关闭;CaseWorkflowPolicy.evaluate 为流转规则唯一事实源。

C 研发实施路线 PHASE 1 → NOW



B+ Resolution 补偿子流程 SUB-WORKFLOW



取消分支:cancelled;退款统一走 Refund Export CSV 批次导出 + SHA-256 校验留痕,后台 /exports 可追踪批次与明细。

FUNCTIONAL REQUIREMENTS

功能需求导图 C 端页面 · B 端模块 · API 端点 · 数据模型

C 端支持免注册(编号 + 手机号)与注册双模式;B 端权限为 ADMIN / MANAGER 双角色,前端按钮级控制、后端为权限权威。

C 端 · 消费者页面 WEB · 6+ PAGES

- / 首页 — 召回品牌检索入口,历史召回浏览
- /recalls/[slug] 召回详情"三刀流" — 3×100vh 叙事:召回概览 → 产品校验 → 发起索赔
- /recalls/[slug]/disposal/[taskId] 消费者处置页 — 处置指引 · 证据上传 · 完成声明 / 例外申报
- /lookup 免注册查询 — 案件编号 + 手机号验证,查看进度与结果
- /dashboard 用户中心 — 我的索赔 / 订单 / 资料(Neon 后端真实认证)
- /faq · /how-it-works · /privacy 内容页 — 流程说明与隐私政策
- 双模式认证 — 游客会话 guest-claim-session(一次性 token)+ 注册制 consumer-auth

B 端 · 管理模块 ADMIN · 10 MODULES

- / 运营总览 + /login Staff 登录(会话刷新 / 下线)
- /campaigns 召回活动 — 只读列表 + 详情 + publish 发布操作
- /cases 案件列表 — 统计卡 · 多维筛选 · 认领 · CSV 导出
- /cases/[id] 案件详情工作台 — 活动产品卡 · 证据卡 · 事故卡 · 两级 PII · 指派 · 状态流转 · Resolution 审批 · Closure Checklist · 审计时间线
- /queues 6 个运营队列 — 分诊 / 补件 / 关闭审查等按角色分流
- /incidents 事故与可报告性关闭 · /exports 退款批次导出
- /access 员工管理 + 审计 · /disposal 处置队列 · /disposal-instructions 内容库

API · 端点矩阵 4 ENDPOINT GROUPS

- /v1 消费者端 — campaigns · product-checks · claim-drafts(+upload-tokens / documents) · claims · case-status-lookups · consumer-auth(register / login / logout / me)
- /admin 管理端 — sessions · staff CRUD · profile · cases(列表 / assign / status / resolution 四操作) · campaigns + publish · incidents + reportability · refund-exports · disposal 全套 · audit-events
- /webhooks 回调 — resend 邮件回执(Svix 验签) · vercel-blob 上传回调
- /internal 定时任务 — jobs/outbox 排空 · jobs/cleanup-drafts(CRON_SECRET 保护) · /health 健康检查
- 契约治理 — OpenAPI 3.1(2258 行)自动生成文档与三端类型,openapi:check 防漂移

数据模型 · 46 表 POSTGRESQL · 24 MIGRATIONS

- campaigns 域 10 表 — versions · localizations · products · variants · identifiers · lots · remedy_options · evidence_requirements · message_templates
- 案件域 — recall_cases · case_consumers · claimed_products · consents · submission_snapshots · claim_drafts · document_uploads
- 处置域 11 表 — instruction_versions · approvals · tasks · evidence_batches · reviews · authorizations · declarations · holds 等
- 事故域 — incidents · reportability_reviews · case_escalations
- 身份与后台 — consumer_users · sessions · staff · 审计事件表
- 支撑域 — communications · outbox_events · idempotency_records · webhook_events · refund_export_batches / items

6+

C 端页面

10

B 端模块

4

API 端点组

46

张数据表

24

个迁移

2258 行

OpenAPI 契约

SECURITY · COMPLIANCE · QUALITY

安全合规与质量保障导图

数据 · 权限 · 防护 · 合规 · 质量

面向 CPSC 监管场景设计:消费者 PII 加密存储、操作全程审计、可报告性闭环,能力未配置时失败关闭(501)而非静默降级。

数据安全 DATA PROTECTION

- **AES-256-GCM 字段加密** — PII 落库加密(FIELD_ENCRYPTION_KEY)
- **HMAC-SHA256 查询哈希** — 密文等值查询(HASH_PEPPER)
- **scrypt 密码哈希** — 消费者与员工凭据
- **两级 PII 脱敏** — 列表掩码 + 详情按需授权展示
- **Vercel Private Blob** — 索赔证据私有存储,非公开链接
- **密钥分层** — FIELD_ENCRYPTION_KEY 与 HASH_PEPPER 独立配置于 .env

访问与权限 ACCESS CONTROL

- **Staff Session 认证** — 登录 · 刷新 · 主动下线
- **RBAC 双角色** — ADMIN / MANAGER 权限矩阵前后端镜像
- **staff.manage 仅 ADMIN** — 员工与权限管理最小化
- **后端为权限权威** — 越权 403 + 拒绝动作写入审计
- **处置细粒度权限** — disposal.review 等独立能力位
- **案件认领制** — cases/assign 指派处理人,责任到人

可靠性与防滥用 RELIABILITY

- **Upstash 跨实例限流** — 案件查询 10 次/分 · 后台登录 5 次/分
- **Idempotency-Key 幂等** — 重复提交不产生重复案件
- **单事务写入 + Outbox** — 建案与通知最终一致
- **失败关闭** — 能力未配置返回 501,不静默降级
- **受保护运维路由** — 缓存失效 / 内部任务需密钥
- **草稿过期清理** — cleanup-drafts 定时任务回收匿名草稿

通信安全 COMMUNICATION

- **Svix webhook 验签** — Resend 回执防伪造
- **一次性 upload token** — 证据直传绑定草稿 + 回调校验
- **恶意软件扫描** — 上传证据经 Vercel Blob 安全检测
- **CRON_SECRET** — outbox / cleanup 内部任务令牌保护
- **9 触点事务邮件** — 品牌模板 · 状态变更即时告知
- **发信域配置** — koiimprtinc.com 自有域名发信

合规与可追溯 COMPLIANCE

- **CPSC 可报告性闭环** — pending → filed(含 CPSC 编号)/documented_non_reportable
- **伤害事故强制升级** — escalated 状态 + Case Escalation
- **closure_review 双门闩** — 处置完成 + 可报告性关闭方可 closed
- **审计事件全留痕** — 关键操作可回溯(audit-events)
- **架构决策记录** — 5 份 ADR + claim-before-disposal 决策
- **先建案后处置** — 处置任务必须挂在已建案件之下

质量保障 QUALITY ASSURANCE

- **Vitest 三层测试** — 静态 → 单元/HTTP → PostgreSQL 集成(gated)
- **D01-D29 验收矩阵** — 处置功能 proven / unproven 分级验收
- **CI 门禁全绿** — typecheck · lint · openapi:check · db:check · vitest
- **三仓库冒烟测试** — 脚本化页面快照与 API 响应留档
- **契约与结构防漂移** — openapi:check + db:check 双检查
- **容量基准脚本** — capacity-benchmark(尚未体系化)

⚠ 遗留风险与待办

邮件时效:Vercel Hobby cron 每日仅一次,通知最长延迟 24h(建议升 Pro) · **负载测试缺失:**容量基准脚本已有(capacity-benchmark)未成体系 · **遗留桥接:**shared-claims-store localStorage 待退出 · **D27:**处置内容包待业务定稿 · **E4:**部分业务材料未齐